

Information Security Policy

University College London

Table of Contents

Purpose	2
Scope	2
Definitions	2
Framework	3
Objectives	3
Policy Statements	4
Policy Owner.....	4
Breach of Policy	4
Legal Compliance	5
Review	5

1 Purpose

1.1 The purpose of this Policy is to ensure the protection of UCL's information assets. Information, regardless of its form or how it is shared or stored, must always be appropriately protected. The focus of this Policy is to ensure that the confidentiality, integrity and availability of information is appropriately managed to support UCL's vision and mission.

2 Scope

- 2.1 This Policy applies to Staff, Students and all other computer, network, or information users authorised by UCL or any of its departments (or equivalent) (collectively referred to as **Users**).
- 2.2 It covers the use of UCL-owned assets (including those leased, rented, or on loan), centrally managed or otherwise; private systems connected to the UCL network; UCL-owned or licensed data and programs; and data and programs provided to UCL by sponsors or external agencies.
- 2.3 Additionally, it pertains to paper files and records created for UCL business purposes.

3 Definitions

- 3.1 **Staff:** all employees of, and other individuals working at, UCL, including agency workers, honorary staff, emeritus staff, visiting staff, external collaborators, contractors and consultants, and the staff and directors of UCL's subsidiary companies. This includes postgraduate students who are employed temporarily or permanently as staff.
- 3.2 **Student:** any individual registered as a student at UCL.
- 3.3 **Data Owner:** A senior member of staff, accountable for overarching strategy and policy setting for information and data within their area of business. Accountable for seeking assurance from **Data Stewards, Information Custodians** and **System Custodians** that suitable controls are in place to mitigate risks to their data. Responsible for ensuring other roles are assigned where applicable.
- 3.4 **Data Steward:** A subject matter expert for an area of structured data held within a university IT system. Responsible for ensuring effective management of the data and resolving any quality issues.

- 3.5 **Information Custodian:** Responsible to the **Data Owner** for one or more of the following in relation to information and data in their business area: Access management; Classification; Risk management; Retention; Records management.
- 3.6 **System Custodian:** A technical administrator for a **System**. Responsible for ensuring security risk are managed within the system. Responsible for providing assurance to the **Data Owner** that suitable controls are in place to mitigate risks to their data.
- 3.7 **System:** any environment that is used in relation to data, such as: network; application; infrastructure; platform; system; appliance; device; service.

4 Framework

- 4.1 UCL's Information Security Policy is underpinned by a set of controls that represent the minimum or baseline requirements for implementation of the policy. These controls will be supported by guidance, standards and/or services. Where necessary, enhanced controls will be applied in accordance with contractual, legal or regulatory requirements. Or, based on the classification or criticality of the information.

5 Objectives

- 5.1 The objectives of this policy are to minimise financial and reputational risk to UCL by:
- 5.2 Protecting UCL's computing facilities, programs, information, network, and equipment against loss, misuse, or abuse.
- 5.3 Ensuring all Users are aware of their Information Security responsibilities and the need for appropriate security measures in information management.
- 5.4 Enabling UCL to deliver its business objectives.
- 5.5 Supporting UCL's ethical, legal and contractual obligations.
- 5.6 Ensuring Users understand their responsibilities for protecting data confidentiality, integrity and availability.
- 5.7 Ensuring secure disposal of information when it is no longer relevant or required.

6 Policy Statements

- 6.1 Data Owners must ensure that all information assets are identified, classified and documented.
- 6.2 All technical assets must have a System Custodian, who must ensure that assets are identified and documented.
- 6.3 System Custodians must ensure processes, technology, services, and facilities are protected by security controls that are appropriate to the classification of the associated information assets.
- 6.4 Data Owners must ensure that risk assessments have been completed on all processes, technologies, services, and facilities that contain information and data within their area of business. Risks must be identified, and appropriate measures implemented to ensure risks remain within UCL's acceptable risk appetite.
- 6.5 Data Owners must ensure that third-party service providers with access to UCL's information undergo a risk assessment to ensure they meet UCL's information security standards.
- 6.6 Users must ensure information security incidents are identified and reported. Incidents will be contained, remediated, investigated and recorded.
- 6.7 Users with access to UCL's information and information systems are responsible for maintaining appropriate security levels as outlined in the supporting standards.
- 6.8 Data Owners must ensure backup and disaster recovery plans, processes, and technology are in place to mitigate the risk of data and service loss or destruction. System Custodians must ensure the availability of information and services is maintained.

7 Policy Owner

- 7.1 This Policy is owned by UCL's Chief Information Security Officer.

8 Breach of Policy

- 8.1 Any breach or suspected breach of this policy may be investigated and treated as a disciplinary matter.

9 Legal Compliance

9.1 Staff and Students have an obligation to abide by all UK legislation. Of particular importance in this respect are:

- The Computer Misuse Act 1990
- The Data Protection Act 2018
- The Human Rights Act 1998
- The Regulation of Investigatory Powers Act 2000
- The Terrorism Act 2006
- The Counter Terrorism and Security Act 2015
- The Police and Justice Act 2006
- The Electronic Communications Act 2000

9.2 This Policy satisfies the Data Protection Act's requirement for a formal statement of UCL's security arrangements for personal data. The requirement for compliance devolves to all Users who may be held personally responsible for any breach of the legislation. Relevant legislation is referenced in supporting policies and guidelines. Full texts are available at <https://www.legislation.gov.uk/ukpga/2018/12/contents>.

10 Review

10.1 This Policy shall be reviewed at least every three years.